

SACI: SIEM Telemetrisi ve Tehdit İstihbaratıyla Açıklanabilir Graf Tabanlı Saldırı Yüzeyi Görünürlük Skorlaması

İsmet Arslan

Özet—Bu çalışma, güvenlik bilgi ve olay yönetimi görünürlüğünü; varlıklar, log kaynakları, tespit kontrolleri, Wazuh kuralları, MITRE ATT&CK teknikleri ve siber tehdit istihbaratı nesneleri arasındaki kapsamla sınırlandırılmış kanıt ilişkileri üzerinden ölçen SACI çerçevesini sunmaktadır. Yöntem, kritik varlık ağırlıklı log kapsamı (CWLC), kontrol/alarm kapsamı (CAC), kapsam içi ATT&CK teknik kapsamı (MDC), CTI bayrak kapanışı (CTIC) ve telemetri tazeliğini (TF) aktif metrik ağırlık normalizasyonu ile birleşik bir görünürlük skoruna dönüştürmektedir. Altı varlıklı kontrollü Wazuh-MISP laboratuvarının nihai yayın anlık görüntüsünde 12/12 beklenen varlık-log kaynağı çifti, 25/25 etkin kontrol, 13/13 kapsam içi teknik ve iki IOC kaydı için 8/8 CTI bayrağı kapanmış; beş bileşen ile birleşik SACI skoru 100 olarak hesaplanmıştır. Yayımlanan graf 97 beyan edilmiş düğüm ve observed=1 durumundaki 171 kenar satırı içermektedir; bütünlük denetimi ayrıca 165 benzersiz ilişki üçlüsü, iki beyan edilmemiş uç ve altı izole düğüm belirlemiştir. Ayrı tutulan 20 senaryolu tarihsel seri, bileşen kayıpları ve iyileştirmeler karşısında beklenen yönlü skor değişimlerini göstermiştir. Laboratuvar topolojisi ve veri yolları yayımlanan kanıtlarla doğrulanabilmekle birlikte kesin yazılım sürümleri ve tam ortam kurulum otomasyonu korunmamıştır. Sonuçlar güvenlik garantisi değil, tanımlı laboratuvar kapsamındaki kanıt kapanışı olarak yorumlanmalıdır.

Anahtar Kelimeler—SACI, SIEM, Wazuh, kanıt grafi, MITRE ATT&CK, siber tehdit istihbaratı, görünürlük skoru, denetlenebilirlik

I. GİRİŞ

Modern güvenlik operasyon merkezleri (SOC), zararlı davranışları tespit etmek ve müdahaleyi önceliklendirmek için uç nokta, kimlik, ağ ve uygulama katmanlarından sürekli telemetri toplar. Bununla birlikte bir SIEM'in kurulu olması, kritik varlıkların beklenen kaynaklarla izlendiğini veya ilgili saldırı tekniklerinin gözlenebilir kanıta sahip olduğunu tek başına göstermez.

Kurumsal saldırı yüzeyinin büyümesi bu ayrımı daha önemli hale getirmektedir. Bulut hizmetleri, uzaktan erişim platformları, güvenlik duvarları, kimlik sağlayıcıları ve üçüncü taraf entegrasyonları parçalı kanıt üretir. Alarm hacmi yüksek olsa bile eski telemetri, kapsam dışı bırakılmış kontroller veya bağlanmamış teknikler kritik kör noktalar yaratabilir.

Bu çalışma şu araştırma sorusunu ele almaktadır: Heterojen SIEM telemetrisi ve tehdit bağlamı, kökeni izlenebilir ve kapsamı açıkça tanımlanmış bir görünürlük skoruna nasıl dönüştürülebilir? SACI; varlıkları, log kaynaklarını, tespit kontrollerini, kuralları, ATT&CK tekniklerini ve CTI nesnelerini tiplenmiş bir kanıt grafiğinde birleştirir.

SACI bir risk, saldırı önleme veya algılama olasılığı modeli değildir. Amaç; tanımlı kanıt evreninde hangi

beklenen ilişkilerin kapandığını, hangi bileşenin skora katkı verdiğini ve hangi veri-bütünlüğü istisnalarının yorum sınırı oluşturduğunu deterministik olarak raporlamaktır.

Çalışmanın katkıları beş başlıkta özetlenebilir: (i) SIEM-CTI kanıtı için tiplenmiş graf şeması; (ii) CWLC, CAC, MDC, CTIC ve TF bileşenlerini N/A metriklerde aktif ağırlıkları yeniden normalize ederek birleştiren uygulanmış skor; (iii) nihai yayın anlık görüntüsü ile bundan ayrı tutulan 20 senaryolu tarihsel duyarlılık serisi; (iv) Wazuh, MISP, pfSense, Windows, Linux, Sysmon, PowerShell ve Ansible rollerini doğrulanmış kanıt ile yeniden üretim gereksinimleri bakımından ayıran laboratuvar kurulumu; (v) ham çıktılar, skorlayıcı, graf oluşturucu ve bütünlük denetimlerini yayımlayan denetlenebilir araştırma eki [13].

II. İLGİLİ ÇALIŞMALAR

A. SIEM Telemetrisi ve Sürekli İzleme

Sürekli izleme, güvenlik durumunun tek seferlik kontroller yerine zaman zaman içinde gözlenen sistem ve kontrol kanıtlarıyla değerlendirilmesini gerektirir [4]. NIST CSF 2.0 da yönetim ve ölçümün kurumsal bağlama bağlanmasını vurgular [5]. SACI bu yaklaşımı varlık-log kaynağı, kontrol-kural ve teknik ilişkilerine uygulamaktadır.

Wazuh, uç nokta izleme, kural tabanlı tespit ve ATT&CK ilişkili kural metaverisi sağlar [2]. Ancak bir kuralda teknik kimliği bulunması, ilgili varlık ve log kaynağının gerçekten gözlemlendiğini veya tespitin dış ortamda etkili olduğunu kanıtlamaz. Bu nedenle SACI, yapılandırma varlığını gözlenen kapsam ilişkilerinden ayırır.

B. MITRE ATT&CK ve Tehdit İstihbaratı

MITRE ATT&CK, saldırgan taktik ve tekniklerini platformlar arası yapılandırılmış bir bilgi tabanı olarak sunar [1]. ATT&CK tabanlı güvenlik değerlendirmelerinin yaygınlığına karşın kapsamın operasyonelleştirilmesi ve sonuçların doğru yorumlanması hâlen açık bir araştırma alanıdır [6]. SACI'nin MDC bileşeni yalnızca önceden beyan edilen teknik alt kümesini sayar.

STIX ve TAXII, tehdit göstergeleri ile ilişkili siber tehdit nesnelerinin makinece okunabilir temsili ve değişimini destekler [3], [11]. CTI modelleri bağlam zenginleştirmeyi kolaylaştırır da bu bağlamın iç telemetriyle nasıl bağlandığı ayrıca doğrulanmalıdır [10]. SACI bu baği dört uygulama bayrağı üzerinden denetlenebilir hale getirir.

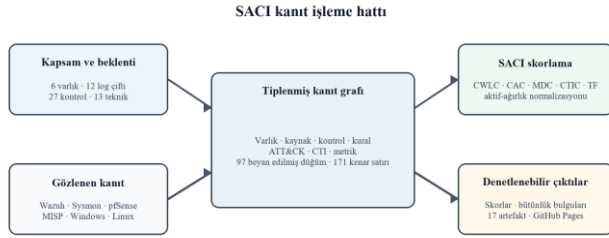
C. Graf Tabanlı Siber Güvenlik Değerlendirmesi

Siber güvenlik bilgi grafları çok kaynaklı varlık, olay, zafiyet ve istihbarat verisini ilişkisel biçimde birleştirerek köken izleme ve karar desteği sağlar [8]. Bununla birlikte kapalı-dünya varsayımları ve sınırlı laboratuvar verisi, gözlenmeyen bir ilişkinin yokluk mu yoksa veri eksikliği mi olduğunu ayırmayı güçleştirebilir [9].

ATT&CK tabanlı puanlama çerçeveleri değerlendirme sonuçlarını teknik kapsam üzerinden özetlemiştir [7]. İleri kalıcı tehdit örnekleri, çok aşamalı davranışların tek bir göstergeye indirgenemeyeceğini göstermektedir [12]. SACI bu literatürü tamamlayarak tespit başarısı yerine kapsamlı sınırlandırılmış SIEM kanıt kapanışını ölçer.

III. ÖNERİLEN MODEL

SACI beş mantıksal katmandan oluşur: kapsam ve varlık envanteri, telemetri/tespit kanıtı, ATT&CK-CTI bağlamı, tiplenmiş graf füzyonu ve aktif-ağırlıkla normalize edilen skorlama. Şekil 1, nihai yayın hattında beklentilerin gözlenen kanıtlarla birleştirilip skor, bütünlük bulgusu ve yayımlanabilir artefakta dönüştürülmesini özetlemektedir.



Şekil 1. SACI kanıt işleme ve yayımlama hattı.

A. Graf Şeması

Graf $G=(V,E)$ olarak tanımlanır. V; varlık, log kaynağı, tespit kontrolü, Wazuh kuralı, ATT&CK tekniği, tiplenmiş CTI nesnesi, platform, entegrasyon, skor metriği ve reason-code düğümlerini içerir. E, kaynak ve hedef kimlikleriyle ifade edilen yönlü, tiplenmiş kanıt satırlarından oluşur.

Nihai yayın grafinde 17 ilişki etiketi örneklenmiştir: alerted_in, collected_by, contains, contains_ioc, contributes_to, converted_to_alert, detects_technique, emits, mapped_to, maps_to, matches_ioc, produces_rule, protected_by, queries, triggers_integration, uses ve uses_log_source. observed=1 bir satırın üretilen kanıt tablosunda kapandığını; observed=0 ise tanımlı fakat kapanmamış satırı belirtir.

Varlık düğümü: kapsam içindeki sistem kimliği, ana bilgisayar adı ve kritiklik değerini temsil eder.

Log kaynağı/kontrol düğümü: beklenen telemetri kaynağını ve bu kanıta bağlı etkin tespit kontrolünü temsil eder.

Kural/teknik düğümü: Wazuh kuralını ve kapsam içindeki ATT&CK teknik eşlemesini temsil eder.

CTI/platform/metrik düğümü: IOC, MISP-Wazuh entegrasyonu ve hesaplanan SACI bileşenlerini temsil eder.

Bütünlük kanıtı: gözlem durumu, benzersiz ilişki üçlüleri, beyan edilmemiş uçlar, izole düğümler ve koşullu reason-code çıktıları birlikte değerlendirilir.

B. Görünürlük Metrikleri

Bileşen skorları $[0,100]$ aralığındadır. Uygulanabilir metrik kümesi M^* için nihai skor, aktif ağırlıkların toplamına bölünerek hesaplanır; N/A metrikler sıfır yapılmaz, pay ve paydadın çıkarılır.

$$SACI = \frac{\sum_{m \in M^*} w_m s_m}{\sum_{m \in M^*} w_m}$$

Nihai değerlendirmede tüm metrikler aktiftir ve ağırlıklar $CWLC=0.30$, $CAC=0.25$, $MDC=0.20$, $CTIC=0.15$ ve $TF=0.10$ 'dur. Ağırlıkların toplamı 1.00'dür; bu değerler tasarım tercihleridir ve olasılık olarak yorumlanmaz.

$$L_a = \frac{\sum_{s \in S_a} w_{as} o_{as}}{\sum_{s \in S_a} w_{as}}$$

$$CWLC = 100 \frac{\sum_{a \in A^*} c_a L_a}{\sum_{a \in A^*} c_a}$$

Gözlem durumu ve kaynak ağırlığı log kaynağı düzeyinde tanımlanır; varlık görünürlüğü kritikliğiyle ağırlıklandırılır.

$$CAC = 100 \frac{\sum_{c \in C} w_c e_c s_c}{\sum_{c \in C} w_c e_c}$$

Yalnızca etkin kontroller pay ve paydaya girer; disabled legacy kontroller CAC paydasından çıkarılır.

$$MDC = 100 \frac{\sum_{t \in T_{scope}} z_t}{|T_{scope}|}$$

MDC, beyan edilmiş kapsam içindeki tekniklerin sayısal kapanışdır; yayımlanan priority alanı skor ağırlığı olarak kullanılmaz.

$$CTIC = \frac{100}{4|I|} \sum_{i \in I} (q_i + h_i + a_i + m_i)$$

Bayraklar sırasıyla lookup icrası, MISP eşleşmesi, Wazuh alarmı ve ATT&CK eşlemesidir. Lookup bayrağının beklenti alanından başlatılması bağımsız sorgu-icrası kanıtı değildir.

$$TF(\Delta, E) = \begin{cases} 100 & E = 1 \wedge \Delta \leq 60 \\ 80 & E = 1 \wedge 60 < \Delta \leq 1440 \\ 50 & E = 1 \wedge \Delta > 1440 \\ 0 & E = 0 \end{cases}$$

E en az bir olayın varlığını, Δ ise skor zamanı ile tüm kaynaklar içindeki en yeni olay arasındaki dakika farkını gösterir. TF kaynak başına tazelik ölçmez.

C. Matematiksel Tanımlar ve Ölçüm Dayanağı

SACI, CWLC, CAC, MDC, CTIC ve TF eşitlikleri önceki bir çalışmadan alınmış hazır risk formülleri değil, bu araştırma için tanımlanan kapsam-sınırlı operasyonel ölçütlerdir. Pay ve paydaların ayrı gösterilmesi; ölçülebilir kapsamı, etkin kontrol durumunu ve gözlenen kanıtı denetlenebilir biçimde ayırır. Bu tasarım, bilgi güvenliği ölçülerinin amaç, kapsam, veri kaynağı, hesaplama yöntemi ve yorum sınırlarıyla birlikte tanımlanmasını öneren NIST SP 800-55 Cilt 1 ve Cilt 2 ile; izleme, ölçme, analiz ve değerlendirme yaklaşımını tanımlayan ISO/IEC 27004:2016 ile yöntemsel olarak uyumludur [26]–[28]. Bununla birlikte bu kaynaklar SACI ağırlıklarını veya tazelik eşiklerini belirlemez: 0.30/0.25/0.20/0.15/0.10 ağırlıkları ve TF kademeleri bu çalışmanın açık tasarım parametreleridir. Ağırlıklı toplam, kanıt kapanışını yorumlanabilir tek bir endekste özetler; olasılık, kayıp beklentisi, saldırı riski ya da tespit doğruluğu tahmini değildir.

D. Açıklanabilirlik Katmanı

Açıklanabilirlik katmanı, bileşen skorlarını bunları üreten varlık, kaynak, kontrol, kural, teknik ve CTI ilişkileriyle birlikte sunar. reason-code mekanizması kapanmayan bir bileşen için deterministik açıklama üretebilir; böylece sonuç yalnızca tek bir toplam puana indirgenmez.

Nihai reason-code çıktısının boş olması, bu çalıştırmada betiklenmiş bir skor boşluğu oluşmadığını gösterir; açıklama mekanizmasının veya veri-bütünlüğü sınırlamalarının bulunmadığı anlamına gelmez. Sayısal sonuç LLM tarafından üretilmez; doğal dil katmanı yalnızca doğrulanmış tablo ve graf kanıtını özetleyebilir.

E. Skorlama Süreci

İşlem hattı beklenen kapsamı tanımlar, türetilmiş gözlem tablolarını oluşturur, beş bileşeni hesaplar, tiplenmiş grafi üretir ve sonuçları bütünlük denetimiyle birlikte yayımlar. Yayımlanan skorlayıcı aktif metrikleri normalize eder; graf oluşturucu aynı kapsam tablolarından izlenebilir ilişki satırları türetir.

Adım 1: Altı varlık ve bunlara ait beklenen varlık-log kaynağı çiftleriyle değerlendirme kapsamını tanımla.

Adım 2: Log kaynağı, etkin kontrol, ATT&CK tekniği ve iki sentetik IOC için gözlem/bayrak tablolarını oluştur.

Adım 3: CWLC, CAC, MDC, CTIC ve TF bileşenlerini uygulanmış formüllerle hesapla.

Adım 4: Düğüm ve ilişki satırlarını üret; observed durumunu ve kanıt kökeni alanlarını taşı.

Adım 5: Uç referanslarını, benzersiz üçlüleri, izole düğümleri, eşleme tutarlılığını ve reason-code çıktısını denetle.

Adım 6: Aktif ağırlıkları yeniden normalize ederek SACI skorunu ve makinece okunabilir araştırma ekini yayımla.

IV. KONTROLLÜ LABORATUVAR KURULUMU VE VERİ HATTI

Deney ortamı, yayımlanan envanterde aynı 192.168.1.x adres uzayında tanımlanan altı mantıksal varlıktan oluşur. Topoloji, telemetri üreten uçları merkezi Wazuh toplama ve tespit katmanına; buradan ATT&CK, MISP ve SACI kanıt ilişkilerine bağlar.

WSIEM (192.168.1.100): merkezi Wazuh toplama, decoder/kural değerlendirme, alarm üretimi ve özel MISP entegrasyon kanıtı.

DC01 (192.168.1.10): Windows Security ve Sysmon; WS01 (192.168.1.111): Security, Sysmon ve PowerShell telemetrisi.

uhost (192.168.1.121): Ubuntu authlog, syslog ve süreç telemetrisi.

FW01-PFSENSE (192.168.1.1): güvenlik duvarı ve pfSense syslog olayları.

CTI01 (192.168.1.101): MISP API, IOC ve zenginleştirme kanıtı.

Değerlendirme evreni: 6 varlık, 12 varlık-log çifti, 27 kontrol satırı, 25 etkin kontrol, 13 kapsam içi ATT&CK tekniği ve 2 sentetik IOC.

A. Doğrulanmış Topoloji ve Kurulum Sınırı

Yayın paketi ortam provisioning betiği içermediğinden laboratuvar kurulumu iki düzeyde raporlanır: yayımlanan varlık, log ve yol kanıtları doğrulanmış deney topolojisini; resmî ürün kılavuzları ise yeniden kurulum için izlenecek

teknik adımları tanımlar. WSIEM merkezi Wazuh düğümüdür. Wazuh'un resmî tek-düğüm hızlı kurulum modeli sunucu, indeksleyici ve gösterge paneli bileşenlerini açıklar; ancak bu bileşenlerin laboratuvarında aynı ana makinede bulunduğu veya belirli bir paket sürümünün kullanıldığı yayın paketinden doğrulanamaz [14].

DC01, WS01 ve uhost üzerindeki telemetri akışı Wazuh ajanı ve merkezi yönetici ilişkisiyle uyumludur. Yeniden kurulumda ajanların işletim sistemine göre kurulması ve benzersiz istemci anahtarlarıyla yöneticiye kaydedilmesi gerekir [15], [16]. Yayımlanan graf bu kaynakların Wazuh'a collected_by ilişkisiyle bağlandığını doğrular; buna karşılık gerçek ajan kurulum komutları, ossec.conf dosyaları, sertifikalar, hypervizör türü ve kesin ürün sürümleri yayımlanmamıştır.

B. Telemetri ve Entegrasyon Yapılandırması

Windows katmanında Security, Microsoft-Windows-Sysmon/Operational ve Microsoft-Windows-PowerShell/Operational kanalları izlenmiştir. Wazuh bu kanalları eventchannel kaynakları olarak toplayabilir [17]; Sysmon XML yapılandırması süreç, ağ ve DNS görünürlüğünü, PowerShell Script Block Logging ise komut içeriğini Operational kanalında üretir [22], [23]. Linux tarafında authlog, syslog ve süreç kanıtı; ağ katmanında pfSense uzak syslog kanıtı gözlenmiştir. Netgate kılavuzu uzak syslog yapılandırmasını açıklar ve korumasız UDP aktarımının şifresiz olduğunu belirtir [21]. Paket, kullanılan Sysmon XML'ini, PowerShell ilke ayarlarını, Linux forwarder yapılandırmasını veya pfSense taşıma protokolünü korumadığından bu ayrıntılar doğrulanmış kurulum gerçeği olarak sunulamaz.

CTI01, MISP API ve iki sentetik IOC kaydıyla tehdit istihbaratı katmanını sağlar. Resmî MISP kılavuzları desteklenen GNU/Linux kurulum akışlarını ve API tabanlı kullanım modelini verir [19], [20]. Laboratuvar grafında Wazuh özel MISP entegrasyonunu tetikler, entegrasyon MISP'i sorgular, IOC eşleşmesini Wazuh alarmına dönüştürür ve ATT&CK bağlamına taşır. Bu desen Wazuh'un Integrator ve dış API bağlayıcılarıyla uyumludur [18]. Bununla birlikte MISP sürümü, kurulum yöntemi, API uç noktası, kimlik bilgileri ve özel bağlayıcı yapılandırması yayımlanmamıştır.

C. Araçların ve Teknolojilerin İşlevsel Roller

Wazuh; uçlardan olay toplama, decoder/kural değerlendirme, alarm üretme ve ATT&CK eşleme katmanıdır [14]–[18]. Sysmon, Windows Security günlüklerinin ötesinde süreç oluşturma, ağ bağlantısı ve DNS gibi yüksek ayrıntılı olaylar üretir; PowerShell günlüklenme komut ve betik içeriğini görünür kılar [22], [23]. pfSense ağ/güvenlik duvarı olaylarını uzak syslog ile sağlar [21]. MISP, IOC ve bağlamsal tehdit istihbaratını saklama, sorgulama ve API ile paylaşma rolündedir [19], [20]. Ansible ve WinRM, Windows senaryolarının uzaktan ve tekrarlanabilir biçimde yürütülmesini sağlar [24]. ATT&CK teknik taksonomisini, STIX tehdit istihbaratı nesnelerinin makinece okunabilir temsilini, TAXII ise bu içeriğin uygulama katmanında değişimini sağlar [25], [29], [30]. Python betikleri deterministik skor ve graf üretimini yürütür; CYJS çıktısı Cytoscape.js ile etkileşimli graf

incelemesine, Mermaid çıktısı ise metin tabanlı ve sürüm denetimine uygun diyagram üretimine hizmet eder [31], [32].

D. Kontrollü Senaryo Orkestrasyonu

Yayınlanan saldırı çalıştırıcısı yalnızca DC01/Windows yolunu yürütür. Betik /opt/windows-control dizininde inventory.ini envanterini kullanır ve Ansible win_shell modülüyle dc01 hedefine bağlanır. Windows yönetimi için Ansible, WinRM ve uygun kimlik doğrulama/şifreleme yapılandırmasına dayanır [24]. Çalıştırıcı Wazuh ana makinesinde zararsız bir Python HTTP sunucusu açar; hesap, etki alanı, ağ ve paylaşım keşfi, DNS IOC sorgusu ve zararsız dosya aktarımı davranışlarını üretir. Her komut senaryo, ATT&CK, kural ve dönüş kodu alanlarıyla JSONL biçiminde kaydedilir.

Çalıştırıcı son komuttan sonra Wazuh ingestion için 90 saniye bekler ve /var/ossec/logs/alerts/alerts.json içindeki ilgili özel kural kimliklerini denetler. Linux, pfSense ve CTI yolları için nihai kapsam ve alarm kanıtı yayımlanmıştır; ancak bu yolları kuran veya davranış üreten eşdeğer betikler araştırma ekinde bulunmaz. Bu nedenle deney, yayımlanan Windows/DC01 orkestrasyonu ile diğer bileşenlerin sonuç kanıtlarını aynı yeniden üretilebilirlik düzeyindeymiş gibi sunmaz.

E. Veri Toplama, Skorlama ve Yayın

Skorlama hattı Wazuh alarmlarını /var/ossec/logs/alerts/alerts.json, MISP zenginleştirme kayıtlarını /var/log/wazuh-misp/misp-enrichment.log, normalize senaryo olaylarını /var/log/saci/saci-scenario-events.log ve pfSense kanıtını /var/log/saci/pfsense-events.log yollarından okur. Varlık ve kaynak ilişkilendirmesi Wazuh agent adı/kimliği, sağlayıcı, kanal, olay konumu, kural kimliği ve ATT&CK metaverisini kullanır. Kapsam envanteri, kontrol tanımları, teknik kapsam, IOC beklentileri ve ağırlıklar /opt/saci-lab/data altındaki CSV girdilerinden alınır.

Yayımlanan Python skorlayıcı bu girdilerden bileşen ve kapsam tablolarını, graf oluşturucu ise düğüm/kenar dosyaları ile CYJS ve Mermaid temsillerini türetir. ATT&CK teknik kimlikleri resmî STIX/TAXII veri kaynaklarıyla doğrulanabilir [25]. Skor ve graf aynı türetilmiş tablolara dayandığından graf bağımsız bir doğrulama veri kümesi değil, skor kökenini izlenebilir kılan temsildir. Yayın paketi koşum betiği, reason-code dosyaları, özet, kaynak kod ve doğrulama manifestini içerir; portal bu değişmez artefaktların üzerine açıklayıcı bir görünüm ekler [13].

F. Tarihsel Duyarlılık Serisi

Nihai yayın anlık görüntüsü birincil sonuçtur. Aynı S0-S18 serisi, SIEM kurulumundan tam kapanışa ve kritik/nonkritik telemetri, CTI, tazelik ile kural kayıplarına uzanan 20 deterministik duyarlılık senaryosu içerir. S7'nin A/B dalları nedeniyle 19 etiket altında 20 koşul bulunur. Tarihsel S8'in 95/173 grafi, farklı kapsam ve graf üretim hattı kullanan nihai 97/171 grafiyle birleştirilmez.

G. Kurulumun Yeniden Üretilirlik Sınırı

Yayımlanan artefaktlar laboratuvar rollerini, IP adreslerini, gözlenen veri yollarını, formülleri ve nihai

çıktıları denetlemeye yeterlidir. Bununla birlikte Wazuh, MISP, pfSense, Sysmon, Windows ve Ubuntu sürümleri; ajan kayıt komutları; özel decoder/kural dosyaları; Sysmon XML'i; PowerShell ilkeleri; pfSense forwarding ayarları; MISP API yapılandırması; sanallaştırma topolojisi ve uçtan uca provisioning otomasyonu korunmamıştır. Bu makaledeki resmî kurulum kaynakları, doğrulanmamış ayrıntıları laboratuvar gerçeği olarak ileri sürmek yerine bağımsız yeniden kurulum için gerekli referans prosedürleri tanımlar.

V. FİNAL SONUÇLAR VE TARTIŞMA

Nihai değerlendirmede 6 varlık için 12/12 varlık-log çifti gözlenmiştir. 27 kontrol satırından C003 ve C004 legacy olarak disabled bırakılmış, kalan 25 etkin kontrolün tamamı görülmüştür. Kapsam içi 13 tekniğin tamamı covered=1; iki IOC kaydındaki dört uygulama bayrağının tamamı 1'dir.

CWLC: 100.0 (ağırlık 0.30; 6 varlık ve 12/12 beklenen log çifti).

CAC: 100.0 (ağırlık 0.25; 25/25 etkin kontrol, aktif ağırlık 23.3/23.3).

MDC: 100.0 (ağırlık 0.20; 13/13 beyan edilmiş kapsam içi teknik).

CTIC: 100.0 (ağırlık 0.15; 2 IOC x 4 bayrak = 8/8).

TF: 100 (ağırlık 0.10; küresel en yeni olay skor çalıştırma anında ≤60 dakika kademesinde).

$$0.30 + 0.25 + 0.20 + 0.15 + 0.10 = 1.00$$
$$SACI = \frac{1.00 \times 100}{1.00} = 100.0$$

SACI=100, tanımlı nihai yayın kanıt evrenindeki bileşen beklentilerinin uygulanmış kurallar altında kapandığını gösterir. Bu sonuç ortamın güvenli olduğunu, tüm saldırıların algılanacağını, tüm Enterprise ATT&CK bilgi tabanının kapsandığını veya yanlış pozitif/negatif oranlarının ölçüldüğünü göstermez.

Graf denetimi 97 beyan edilmiş düğüm, observed=1 durumunda 171 kenar satırı, 165 benzersiz kaynak-ilişki-hedef üçlüsü ve 17 ilişki etiketi bulmuştur. LOGSOURCE:Wazuh ile MITRE:T1071.001 düğüm tablosunda beyan edilmemiş uçlardır; altı düğüm izole edilir. Ayrıca 110203 kuralı kontrol tablosunda T1071.001, CTIC tablosunda T1071.004 ile eşleşir. Bu nedenle 171/171 satır kapanışı kusursuz referans bütünlüğü olarak yorumlanamaz.

Tarihsel duyarlılık serisi beklenen yönlü değişimleri üretmiştir: S0'da 0.00 olan skor S6 CTI entegrasyonunda 94.00 ve tarihsel S8 kapanışında 100.00 olmuştur. Kritik DC01 Sysmon kaybı S7A'da 78.53'e, nonkritik WS01 kaybı S7B'de 92.52'ye; CTI kaybı S12/S13'te 92.50'ye ve tazelik düşüşü S15'te 95.00'e gerilemiştir. S17 iyileştirme sonrası 100.00'dir.

A. Geçerlik ve Sınırlılıklar

Yapı geçerliği bakımından SACI önceden tanımlanmış kanıt kapanışını ölçer; algılama olasılığı, önleme etkinliği, yanlış alarm oranı, MTTD veya artık risk ölçmez. İç geçerlik, çalıştırıcı ve skorlayıcıdaki beklenen kural/teknik alanlarına bağlıdır; bazı kayıtlar koşum dönüş kodundan bağımsız olarak beklenen etiketleri taşıyabilir. CTIC lookup bayrağı da expected_lookup'tan başlatılır.

Dış geçerlik tek bir altı-varlıklı Wazuh-MISP laboratuvarı, iki sentetik IOC ve 13 seçili teknikle sınırlıdır.

TF küresel en yeni olayı kullandığından bir taze kaynak eski kaynakları maskeleyebilir ve kesin skorlayıcı zamanı yayımlanmadığı için olay yaşı bağımsız olarak yeniden kurulamaz. Upstream /opt/saci-lab/data girdileri, ham canlı log anlık görüntüsü ve tam ortam otomasyonu yayımlanmadığından paket aritmetik/graf denetimini destekler, uçtan uca bağımsız yeniden yürütmeyi değil.

VI. UYGULAMA VE DENETLENEBİLİRLİK

Uygulama; yayımlanan Windows senaryo çalıştırıcısı, deterministik Python skorlayıcısı ve graf oluşturunca oluşur. Araştırma eki 17 makinece okunabilir dosya yayımlar: kapsam CSV'leri, skor JSON/CSV'leri, düğüm/kenar tabloları, CYJS/Mermaid grafi, reason-code çıktıları ve kaynak kod. Gömülü SHA-256 denetimleri bu dosyaların yayın kimliğini doğrular.

Etkileşimli GitHub Pages portalı yöntem, mimari, nihai kanıt tabloları, senaryo seçicili graf ve artefakt haritasını tek araştırma eki altında sunar [13]. Portal; nihai yayın ile tarihsel senaryoları ayrı etiketler, beyan edilmemiş graf uçlarını görsel yer tutucu olarak açıklar ve skor yorum sınırını görünür tutar.

VII. DENETİM PROTOKOLÜ VE OPERASYONEL YORUM

A. Yayın Katmanları ve Denetim Zinciri

Denetim protokolü üç kanıt katmanını birbirinden ayırır: beyan edilmiş değerlendirme kapsamı, bu kapsamdan türetilen gözlem tabloları ve yayımlanan skor/graf artefaktları. Birinci katman varlık, kaynak, kontrol, teknik ve IOC paydalarını; ikinci katman observed, enabled, covered ve uygulama bayraklarını; üçüncü katman ise bileşen skorlarını, ilişki satırlarını ve bütünlük bulgularını taşır. Bağımsız bir denetçi CSV ve JSON dosyalarından pay ve paydaları yeniden hesaplayabilir, 171 kenar satırını 165 benzersiz üçlüye indirgeme işlemini yineleyebilir ve beyan edilmemiş uçları düğüm tablosuyla karşılaştırabilir. SHA-256 denetimleri yayın paketinin kimliğini sabitler; ancak upstream telemetrinin özgünlüğünü veya koşumun eksiksiz yürütüldüğünü tek başına kanıtlamaz. Benzer biçimde boş reason-code çıktısı yalnızca uygulanmış kuralların açıklama üretmediğini gösterir. Bu nedenle SACI, deterministik paket denetimi ile tam deneysel yeniden üretimi açıkça farklı güvence düzeyleri olarak ele alır.

B. Skorların Karar Semantiği

Her değerlendirme yalnızca birleşik SACI değeriyle değil, beş bileşenli skor vektörü, aktif metrik kümesi, ağırlıklar ve kapsam kimliğiyle birlikte okunmalıdır. Aktif-ağırlık normalizasyonu N/A bir bileşenin yapay olarak sıfır yazılmasını önler; buna karşılık aktif metrik kümesi değişen iki koşum, paydaları farklı olduğundan doğrudan karşılaştırılmaz. Aynı ilke kapsamın, kontrol durumlarının ve teknik listesinin sürümlenmesini gerektirir. Belgelenmiş bir politika uyarınca disabled legacy kontroller CAC paydasından çıkarılabilirken, etkin fakat gözlenmeyen bir kontrol boşluk olarak kalmalıdır. Kritik varlık ağırlıkları da S7A ve S7B arasındaki asimetrisinin tasarlanmış nedenidir; bu fark olasılıksal risk tahmini değildir. SACI bu koşullar altında yayın kapısı, kanıt-tamlık denetimi veya sabit kapsamlı zaman serisi göstergesi olarak kullanılabilir. Farklı

kapsamlar arasında ürün, ekip ya da kurum sıralaması üretmek ise ek kalibrasyon ve dış doğrulama olmadan metodolojik olarak savunulamaz.

C. Duyarlılık ve Arıza Semantiği

S0-S18 serisindeki 20 senaryo bağımsız istatistiksel gözlemler değil, formüllere uygulanan deterministik bozma ve iyileştirme deneyleridir. Seri; boş başlangıçtan CTI entegrasyonuna ve tam kapanışa yükselişi, kritik ile nonkritik telemetri kaybının farklı etkisini, CTI bayraklarının kaldırılmasını ve tazelik kademesinin gerilemesini sınar. S7A'nın S7B'den daha düşük olması kritik ağırlığın; S12/S13'ün 92.50'de eşitlenmesi aynı CTIC kaybının; S15'in 95.00'e gerilemesi ise TF ağırlığının beklenen yönlü etkisini doğrular. Bu deneyler skorlayıcının girdilere duyarlı olduğunu ve ağırlık sıralamasını uyguladığını gösterir. Bununla birlikte tekrar koşumları, dağılım varsayımları, güven aralıkları veya bağımsız saha örnekleri bulunmadığından nedensel etki büyüklüğü ya da öngörü başarısı çıkarılamaz. İstatistiksel geçerlik için çoklu laboratuvarlarda önceden kaydedilmiş hipotezler, tekrarlı koşumlar ve gerçek olay sonuçlarıyla ayrı bir çalışma gerekir.

D. Üretimleştirme İlkeleri

Üretim kullanımı için hesaplama hattı başarısız koşumlarda kapalı kalmalı; her gözlem koşum kimliği, gerçek alarm veya olay kimliği, kaynak zaman damgası ve dosya özetileyle bağlanmalıdır. Tazelik küresel en yeni olay yerine kaynak bazında hesaplanmalı, şema kontrolleri eksik veya beklenmeyen sütunları reddetmeli ve graf oluşturunca beyan edilmemiş uçları yalnızca raporlamakla kalmayıp bütünlük politikasına göre koşumu geçersiz kılabilmelidir. 110203 kuralındaki T1071.001/T1071.004 ayrımı tek bir sürümlü eşleme kaynağında uzlaştırılmalıdır. Kapsam, ağırlık ve eşik yapılandırılmaları sonuçla birlikte yayımlanmalı; portal, ham artefaktları yerinde düzeltmeden aynı sürümden türetilmelidir. Sürekli bütünleştirme testleri skor-graf tutarlılığını, benzersiz ilişki anahtarlarını, izole düğüm politikasını ve reason-code kapsamasını denetleyebilir. Son olarak dış geçerlik, aynı protokolün farklı SIEM ürünleri, ağ topolojileri ve bağımsız saha ekipleri tarafından uygulanmasıyla sınanmalıdır.

VIII. SONUÇ

SACI, önceden tanımlanmış bir SIEM-CTI kanıt evrenini izlenebilir graf modeli ve aktif ağırlıklarla normalize edilen birleşik görünürlük skoruna dönüştürmenin uygulanabilir olduğunu göstermiştir. Nihai değerlendirmede tüm beş bileşenin 100 olması; 12/12 log çifti, 25/25 etkin kontrol, 13/13 kapsam içi teknik ve 8/8 CTI bayrağının kapanışıyla aritmetik olarak doğrulanmıştır.

Bununla birlikte sonuç kapsamla sınırlıdır. Gelecek çalışmalar gerçek alarm kimliği ve zaman damgasına dayalı kanıt kökenini zorunlu kılmalı, başarısız koşumları skordan dışlamalı, T1071.001/T1071.004 eşlemesini uzlaştırmalı, kaynak-bazlı tazelik ölçümü eklemeli, referans bütünlüğünü otomatik test etmeli ve tam ortam/ham veri anlık görüntüleriyle çok sahalı dış doğrulama yapmalıdır.

IX. VERİ VE ARTEFAKT ERİŞİLEBİLİRLİĞİ

Nihai skor, kapsam, reason-code, graf ve kaynak kod artefaktları ile etkileşimli araştırma eki SACI Final Evidence Portal'da yayımlanmıştır [13].

KAYNAKLAR

- [1] The MITRE Corporation, "Enterprise Matrix," MITRE ATT&CK. Accessed: Jun. 21, 2026. [Online]. Available: <https://attack.mitre.org/matrices/enterprise/>
- [2] Wazuh, "MITRE ATT&CK framework - Data analysis," Wazuh Documentation. Accessed: Jun. 21, 2026. [Online]. Available: <https://documentation.wazuh.com/current/user-manual/ruleset/mitre.html>
- [3] OASIS Cyber Threat Intelligence TC, "STIX Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [4] K. Dempsey, N. Chawla, A. Johnson, R. Johnston, A. Jones, A. Orebaugh, M. Scholl, and K. Stine, "Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations," NIST Special Publication 800-137, 2011.
- [5] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0," NIST Cybersecurity White Paper, 2024.
- [6] B. Al-Sada, A. Sadighian, and G. Oligeri, "MITRE ATT&CK: State of the Art and Way Forward," arXiv:2308.14016, 2023.
- [7] H. Manocha, A. Srivastava, C. Verma, R. Gupta, and B. Bansal, "Security Assessment Rating Framework for Enterprises using MITRE ATT&CK Matrix," arXiv:2108.06559, 2021.
- [8] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, "A review of knowledge graph application scenarios in cyber security," arXiv:2204.04769, 2022.
- [9] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in Proc. IEEE Symposium on Security and Privacy, 2010, pp. 305-316.
- [10] V. Mavroeidis and S. Bromander, "Cyber threat intelligence model: An evaluation of taxonomies, sharing standards, and ontologies within cyber threat intelligence," in Proc. 2017 European Intelligence and Security Informatics Conference, 2017, pp. 91-98.
- [11] OASIS Cyber Threat Intelligence TC, "TAXII Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/taxii/v2.1/taxii-v2.1.html>
- [12] M. Ussath, D. Jaeger, F. Cheng, and C. Meinel, "Advanced persistent threats: Behind the scenes," in Proc. 2016 Annual Conference on Information Science and Systems, 2016, pp. 181-186.
- [13] İ. Arslan, "SACI Final Evidence Portal: araştırma artefaktı," 2026. [Çevrimiçi]. Erişim: <https://4rslanismet.github.io/saci-final-evidence/> Erişim tarihi: 11 Temmuz 2026.
- [14] Wazuh, "Quickstart," Wazuh Documentation. [Çevrimiçi]. Erişim: <https://documentation.wazuh.com/current/quickstart.html> Erişim tarihi: 11 Temmuz 2026.
- [15] Wazuh, "Wazuh agent - Installation guide," Wazuh Documentation. [Çevrimiçi]. Erişim: <https://documentation.wazuh.com/current/installation-guide/wazuh-agent/index.html> Erişim tarihi: 11 Temmuz 2026.
- [16] Wazuh, "Wazuh agent enrollment," Wazuh Documentation. [Çevrimiçi]. Erişim: <https://documentation.wazuh.com/current/user-manual/agent/enrollment/index.html> Erişim tarihi: 11 Temmuz 2026.
- [17] Wazuh, "Configuring log collection for different operating systems," Wazuh Documentation. [Çevrimiçi]. Erişim: <https://documentation.wazuh.com/current/user-manual/capabilities/log-data-collection/configuration.html> Erişim tarihi: 11 Temmuz 2026.
- [18] Wazuh, "External API integration," Wazuh Documentation. [Çevrimiçi]. Erişim: <https://documentation.wazuh.com/current/user-manual/manager/integration-with-external-apis.html> Erişim tarihi: 11 Temmuz 2026.
- [19] MISP Project, "Welcome to the official MISP Install Guides." [Çevrimiçi]. Erişim: <https://misp.github.io/MISP/> Erişim tarihi: 11 Temmuz 2026.
- [20] MISP Project, "MISP Documentation and Support." [Çevrimiçi]. Erişim: <https://www.misp-project.org/documentation/> Erişim tarihi: 11 Temmuz 2026.
- [21] Netgate, "Remote Logging with Syslog," pfSense Documentation. [Çevrimiçi]. Erişim: <https://docs.netgate.com/pfsense/en/latest/monitoring/logs/remote.html> Erişim tarihi: 11 Temmuz 2026.
- [22] M. Russinovich ve T. Garnier, "Sysmon v15.21," Microsoft Sysinternals, 17 Haziran 2026. [Çevrimiçi]. Erişim: <https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon> Erişim tarihi: 11 Temmuz 2026.
- [23] Microsoft, "about Logging," Microsoft Learn - Windows PowerShell 5.1. [Çevrimiçi]. Erişim: https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_logging?view=powershell-5.1 Erişim tarihi: 11 Temmuz 2026.
- [24] Ansible Project, "Windows Remote Management," Ansible Core Documentation. [Çevrimiçi]. Erişim: https://docs.ansible.com/projects/ansible-core/2.17/os_guide/windows_winrm.html Erişim tarihi: 11 Temmuz 2026.
- [25] MITRE, "ATT&CK Data & Tools," MITRE ATT&CK. [Çevrimiçi]. Erişim: <https://attack.mitre.org/resources/attack-data-and-tools/> Erişim tarihi: 11 Temmuz 2026.
- [26] K. Schroeder, H. Trinh ve V. Pillitteri, "Measurement Guide for Information Security: Volume 1—Identifying and Selecting Measures," NIST SP 800-55 Vol. 1, Aralık 2024, doi: 10.6028/NIST.SP.800-55v1.
- [27] K. Schroeder, H. Trinh ve V. Pillitteri, "Measurement Guide for Information Security: Volume 2—Developing an Information Security Measurement Program," NIST SP 800-55 Vol. 2, Aralık 2024, doi: 10.6028/NIST.SP.800-55v2.
- [28] ISO/IEC, "ISO/IEC 27004:2016—Information technology—Security techniques—Information security management—Monitoring, measurement, analysis and evaluation," 2. baskı, Aralık 2016. [Çevrimiçi]. Erişim: <https://www.iso.org/standard/64120.html> Erişim tarihi: 12 Temmuz 2026.
- [29] B. Jordan, R. Piazza ve T. Darley, ed., "STIX Version 2.1," OASIS Standard, 10 Haziran 2021. [Çevrimiçi]. Erişim: <https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html> Erişim tarihi: 12 Temmuz 2026.
- [30] B. Jordan, R. Piazza ve T. Darley, ed., "TAXII Version 2.1," OASIS Standard, 10 Haziran 2021. [Çevrimiçi]. Erişim: <https://docs.oasis-open.org/cti/taxii/v2.1/os/taxii-v2.1-os.html> Erişim tarihi: 12 Temmuz 2026.
- [31] M. Franz, C. T. Lopes, G. Huck, Y. Dong, O. Sumer ve G. D. Bader, "Cytoscape.js: a graph theory library for visualisation and analysis," Bioinformatics, c. 32, no. 2, ss. 309–311, 2016, doi: 10.1093/bioinformatics/btv557.
- [32] Mermaid, "About Mermaid," Mermaid Documentation. [Çevrimiçi]. Erişim: <https://mermaid.js.org/intro/> Erişim tarihi: 12 Temmuz 2026.